

UNIT - VI

6

Security

Syllabus

Introduction, Security services, Need of Security, Key Principles of Security, Threats and Vulnerabilities, Types of Attacks, ITU-T X.800 Security Architecture for OSI, Security Policy and mechanisms, Operational Model of Network Security, Symmetric and Asymmetric Key Cryptography. Security in Network, Transport and Application: Introduction of IPSec, SSL, HTTPS, S/MIME, Overview of IDS and Firewalls.

Contents

- 6.1 Introduction
- 6.2 Threats and Vulnerability
- 6.3 Types of Attacks
- 6.4 X.800 Security
- 6.5 Security Policy and Mechanism
- 6.6 Operational Model of Network Security
- 6.7 Symmetric Key Cryptography
- 6.8 Asymmetric Key Cryptography
- 6.9 Security in Network, Transport and Application Layer
- 6.10 Secure Socket Layer
- 6.11 HTTPS
- 6.12 S / MIME
- 6.13 Overview of IDS
- 6.14 Firewalls
- 6.15 Multiple Choice Questions

6.1 Introduction

- How to protect the valuable assets ? It is necessary to keep in safe place like a bank to protect the valuable assets. But bank is not a safe place now. There are so many example where bank robbery in our country.
- Bank robbery is the crime of stealing from a bank during opening hours. Protecting assets was difficult and not always effective.
- Protection is easier because many factors working against the potential criminal. Very sophisticated alarm and camera systems silently protect secure places like banks.
- Traditionally information security provided by physical i.e. rugged filing cabinets with locks and administrative mechanisms i.e. personnel screening procedures during hiring process.
- Asset protection systems are designed to recover stolen cash and high value assets, apprehend criminals and deter crime. The system has the capacity to track, protect and manage critical assets in real-time.
- The techniques of criminal investigation have become so effective that a person can be identified by genetic material, voice, retinal pattern, fingerprints etc.
- Use of networks and communications links requires measures to protect data during transmission.
- **Data security** is the science and study of methods of protecting data from unauthorized disclosure and modification.
- Data and information security is about enabling collaboration while managing risk with an approach that balances availability versus the confidentiality of data.
- **Computer security** : Generic name for the collection of tools designed to protect data and to thwart hackers.
- **Network security** : Measures to protect data during their transmission.
- **Internet security** : Measures to protect data during their transmission over a collection of interconnected networks.

Protecting valuables

- Following are certain aspects for the need of security :
 1. Increasing threat of attacks.
 2. Fast growth of computer networking for information sharing.
 3. Availability of number of tools and resources on Internet.
 4. Lack of specialized resources that may be allotted for securing system.

6.1.1 Need of Security

- Following are the examples of security violations.
 1. User A transmits a sensitive information file to user B. The unauthorised user C is able to monitor the transmission and capture a copy of the file during its transmission.
 2. A message is sent from a customer to a stockbroker with instructions for various transactions. Subsequently, the investments lose value and the customer denies sending the message.
 3. While transmitting the message between two users, the unauthorised user intercepts the message, alters its contents to add or delete entries, and then forwards the message to destination user.
- Security is required because the widespread use of data processing equipment, the security of information felt to be valuable to an organization was provided primarily by physical and administrative means.
- Network security measures are needed to protect data during their transmission.

6.1.2 Basic Terminologies

- Basic terminology used for security purposes are as follows :
 - a. **Cryptography** : The art or science encompassing the principles and methods of transforming an plaintext message into one that is unintelligible and then retransforming that message back to its original form.
 - b. **Plaintext** : The original message.
 - c. **Ciphertext** : The transformed message produced as output, It depends on the plaintext and key.
 - d. **Cipher** : Cryptographic system is called as cipher.
 - e. **Key** : Some critical information used by the cipher, known only to the sender and receiver.
 - f. **Encryption** : The process of converting plaintext to ciphertext using a cipher and a key.
 - g. **Decryption** : The process of converting ciphertext back into plaintext using a cipher and a key.
 - h. **Cryptanalysis** : The study of principles and methods of transforming an unintelligible message back into an intelligible message *without* knowledge of the key. Also called **code-breaking**. Cryptanalysis is to break an encryption. Cryptanalyst can do any or all of the three different things :
 1. Attempt to break a single message.

2. Attempt to recognize patterns in encrypted messages, in order to be able to break subsequent ones by applying a straightforward decryption algorithm.
 3. Attempt to find general weakness in an encryption algorithm, without necessarily having intercepted any messages.
- i. **Cryptology** : Both cryptography and cryptanalysis.
 - j. **Code** : An algorithm for transforming an plaintext message into an unintelligible one using a code-book.

6.1.3 Security Goals

- Security goals are as follows :
 1. Confidentiality
 2. Integrity
 3. Availability.

1. Confidentiality

- Confidentiality ensures that no one can read the message except intended receiver.
- Confidentiality refers to limiting information access and disclosure to authorized users and preventing access by or disclosure to unauthorized ones.
- Sensitive information should be kept secret from individuals who are not authorized to see the information.
- Underpinning the goal of confidentiality are authentication methods like user-IDs and passwords that uniquely identify a data system's users, and supporting control methods that limit each identified user's access to the data system's resources.
- Confidentiality is not only applied to storage of data but also applies to the transmission of information.
- Confidentiality means that people cannot read sensitive information, either while it is on a computer or while it is traveling across a network.
- Fig. 6.1.1 shows relationship between confidentiality integrity and availability.

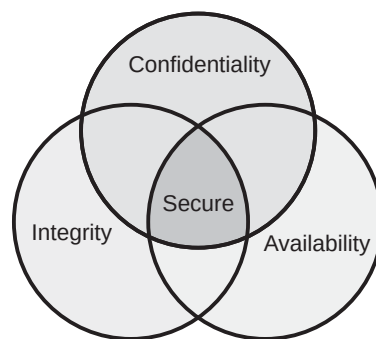


Fig. 6.1.1 Relationship between confidentiality integrity and availability

2. Integrity

- Integrity ensures that received message has not been altered in any way from origin.
- Integrity refers to the trustworthiness of information resources.
- Integrity should not be altered without detection.

- It includes the concept of "data integrity" namely, that data have not been changed inappropriately, whether by accident or deliberately malign activity.
- It also includes "origin" or "source integrity" that is, that the data actually came from the person or entity you think it did, rather than an imposter.
- Integrity ensures that information is not changed or altered in transit. Under certain attack models, an adversary may not have the power to impersonate an authenticated party or understand a confidential communication, but may have the ability to change the information being transmitted.
- On a more restrictive view, however, integrity of an information system includes only preservation without corruption of whatever was transmitted or entered into the system, right or wrong.

3. Availability

- Availability refers, to the availability of information resources. An information system that is not available when you need it is at least as bad as none at all.
- Availability means that people who are authorized to use information are not prevented from doing so. It may be much worse, depending on how reliant the organization has become on a functioning computer and communications infrastructure.
- Almost all modern organizations are highly dependent on functioning information systems. Many literally could not operate without them.
- Availability, like other aspects of security, may be affected by purely technical issues (e.g. a malfunctioning part of a computer or communications device), natural phenomena (e.g. wind or water), or human causes (accidental or deliberate).
- For example, an object or service is thought to be available if
 - i. It is present in a usable form.
 - ii. It has capacity enough to meet the services needs.
 - iii. The service is completed an acceptable period of time.
- By combining these goals, we can construct the availability. The data item, service or system is available if
 - i. There is a timely response to our request.
 - ii. The service and system can be used easily.
 - iii. Concurrency is controlled.
 - iv. It follows the fault tolerance.
 - v. Resources are allocated fairly.

6.2 Threats and Vulnerability

- Computer based systems have three valuable components : **Hardware, software and data.**
- Securities of these components are evaluated in terms of vulnerability, threats, attacks and control.
- An assault on system security that derives from an intelligent threat; that is, an intelligent act that is a deliberate attempt to evade security services and violate the security policy of a system.

Asset

- Asset means people, property and information.
- People may include employees and customers along with other invited persons such as contractors or guests.

Vulnerability

- Vulnerability refers to the security flaws in a system that allows an attack to be successful.
- Weaknesses or gaps in a security program that can be exploited by threats to gain unauthorized access to an asset. Vulnerability is a weakness or gap in our protection efforts.
- **Example** : In design, implementation or procedure, that might be exploited to cause loss or harm.

Threat

- Anything that can exploit vulnerability, intentionally or accidentally, and obtain, damage, or destroy an asset. A threat is what we're trying to protect against.
- Threat refers to the source and means of a particular type of attack.
- A threat assessment is performed to determine the best approaches to securing a system against a particular threat, or class of threat.
- A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit vulnerability.
- Where risk assessments focus more on analyzing the potential and tendency of one's resources to fall prey to various attacks, threat assessments focus more on analyzing the attacker's resources.
- Analyzing threats can help one develop specific security policies to implement in line with policy priorities and understand the specific implementation needs for securing one's resources.

- Threats come in many forms, depending on their mode of attack. From viruses to trojans, spyware and bots, threats have evolved into sophisticated programs intended to harm computers.

Risk

- The potential for loss, damage or destruction of an asset as a result of a threat exploiting vulnerability. Risk is the intersection of assets, threats, and vulnerabilities.
- The formula used to determine risk is

$$\text{Risk} = \text{Asset} + \text{Threat} + \text{Vulnerability}$$

$$R = A + T + V$$

- Risk is a function of threats exploiting vulnerabilities to obtain damage or destroy assets. Thus, threats may exist, but if there are no vulnerabilities then there is little/no risk.
- Similarly, you can have vulnerability, but if you have no threat, then you have little/no risk.

Control

- Control is used as proactive measure. Control is a action, device, procedure, or technique that removes or reduces a vulnerability.
- A threat is blocked by control of vulnerability.
- Interception, interruption, modification and fabrication are the system security threats.

6.3 Types of Attacks

- Security attacks are of two types :
 1. Passive attacks
 2. Active attacks

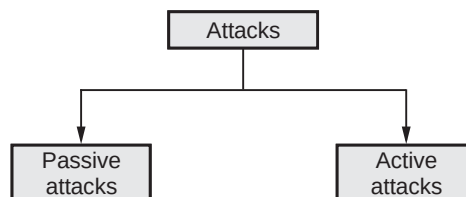


Fig. 6.3.1

6.3.1 Passive Attacks

- Passive attacks are those, wherein the attacker indulges in eavesdropping on, or monitoring of data transmission. A passive attack attempts to learn or make use of information from the system but does not affect system resources.
- The attacker aims to obtain information that is in transit. The term passive indicates that the attacker does not attempt to perform any modifications to the data.
- **Passive attacks** are of two types :
 1. Release of message contents
 2. Traffic analysis

- **Release of message content** is shown in Fig. 6.3.2. A telephone conversation, an electronic mail message and a transferred file may contain sensitive or confidential information we would like to prevent an opponent from learning the content of these transmissions.

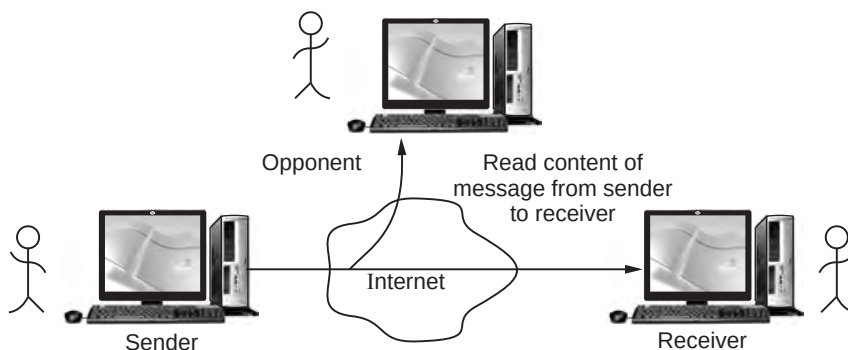


Fig. 6.3.2 Release of message contents

- **Traffic analysis** : Mask the contents of message so that opponents could not extract the information from the message. Encryption is used for masking. Fig. 6.3.3 shows the traffic analysis.

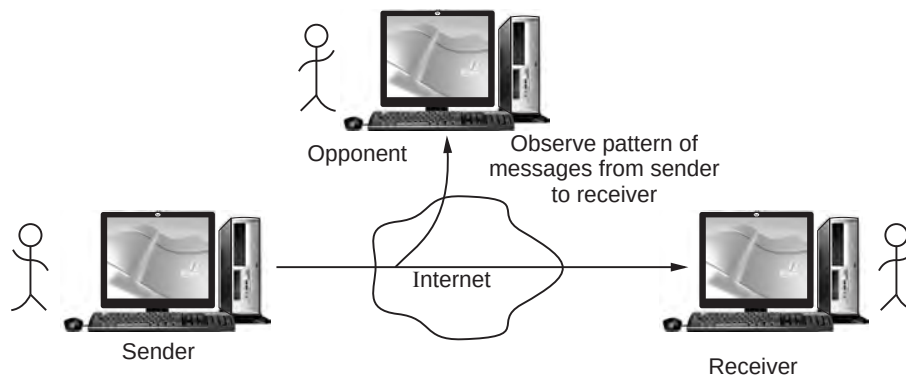


Fig. 6.3.3 Traffic analysis

- Passive attacks are very difficult to detect because they do not involve any alternation of data. It is feasible to prevent the success of attack, usually by means of encryption.

6.3.2 Active Attacks

- Active attacks involve some modification of the data stream or the creation of a false stream. These attacks can not be prevented easily.
- Active attacks can be subdivided into four types :
 1. Masquerade
 2. Replay
 3. Modification of message
 4. Denial of service

1. Masquerade

- It takes place when one entity pretends to be a different entity. Fig. 6.3.4 shows masquerade.

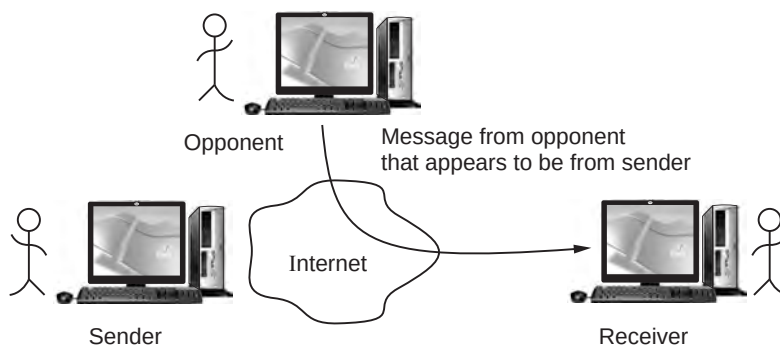


Fig. 6.3.4 Masquerade

- **For example :** Authentication sequences can be captured and replayed after a valid authentication sequence has taken place, thus enabling an authorized entity with few privileges to obtain extra privileges by impersonating an entity that has those privileges.
- **Interruption** attacks are called as masquerade attacks.

2. Replay

- It involves the passive capture of a data unit and its subsequent retransmission to produce an unauthorized effect.
- Fig. 6.3.5 shows replay attack.

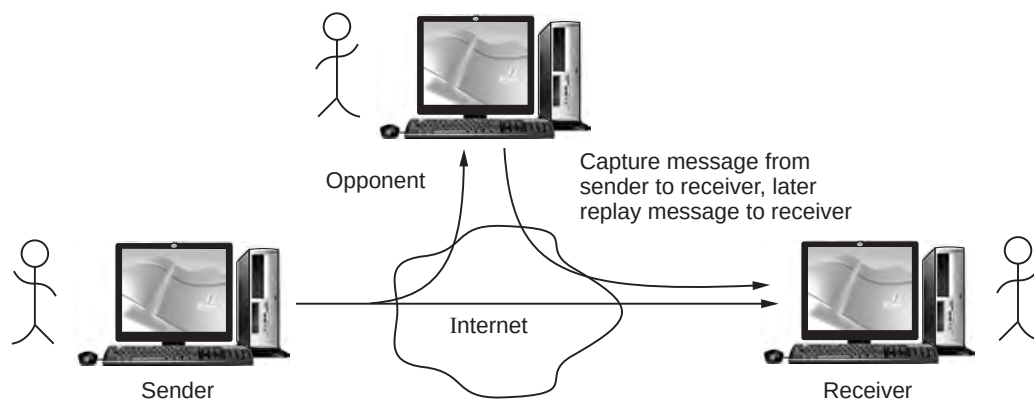


Fig. 6.3.5 Replay

3. Modification of message

- It involves some change to the original message. It produces an unauthorized effect. Fig. 6.3.6 shows the modification of message.

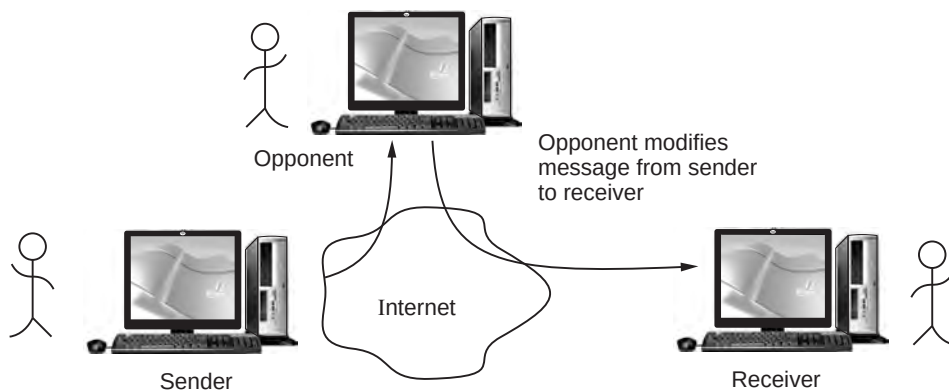


Fig. 6.3.6 Modification of message

- For example, a message meaning "Allow Rupali Dhotre to read confidential file accounts " is modified to mean "Allow Mahesh Awati to read confidential file accounts".

4. Denial of service

- Fabrication causes Denial Of Service (DOS) attacks.
- DOS prevents the normal use or management of communications facilities.
- Another form of service denial is the disruption of an entire network, either by disabling the network or by overloading it with messages so as to degrade performance.
- Fig. 6.3.7 shows denial of service attack.

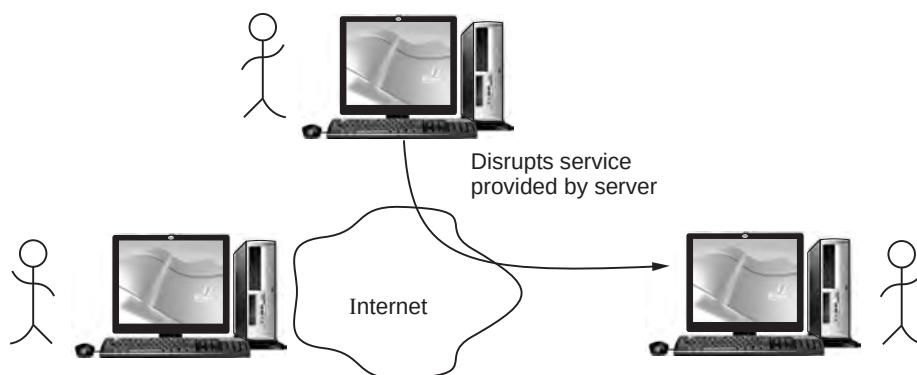


Fig. 6.3.7 Denial of service

- It is difficult to prevent active attack because of the wide variety of potential physical, software and network vulnerabilities.
- The first type of DOS attacks were single source attacks, meaning that a single system was used to attack another system and cause something on that system to fail. SYN flood is the most widely used DOS attack.

- Fig. 6.3.8 shows the SYN flood DOS attack.

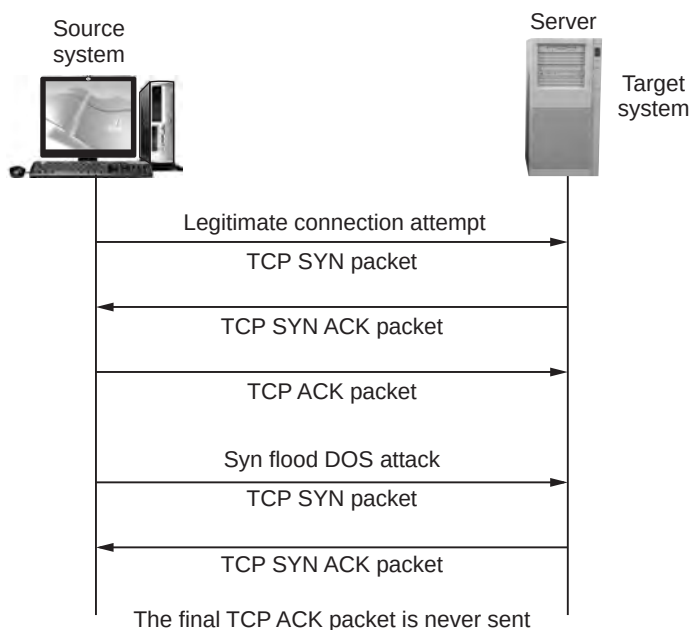


Fig. 6.3.8 SYN flood DOS attack

- Source system sends a large number of TCP SYN packets to the target system. The SYN packets are used to begin a new TCP connection.
- When the target receives a SYN packet, it replies with TCP SYN ACK packet, which acknowledges the SYN packet and sends connection setup information back to the source of the SYN.
- The target also places the new connection information into a pending connection buffer.
- For a real TCP connection, the source would send a final TCP ACK packet when it receives the SYN ACK.
- However, for this attack, the source ignores the SYN ACK and continues to send SYN packets. Eventually, the target's pending connection buffer fills up and it can no longer respond to new connection requests.

6.3.3 Difference between Passive and Active Attack

Sr. No.	Passive attacks	Active attacks
1.	Passive attacks are in the nature of eavesdropping on, or monitoring of, transmissions.	Active attacks involve some modification of the data stream or the creation of a false stream.

2.	Types : Release of message contents and traffic analysis	Types : Masquerade, replay, modification of message and denial of service.
3.	Very difficult to detect.	Easy to detect.
4.	The emphasis in dealing with passive attacks is on prevention rather than detection.	It is quite difficult to prevent active attacks absolutely.
5.	It does not affect the system.	It affects the system.

6.4 X.800 Security

X.800 defines a security service as a service provided by a protocol layer of communicating open systems, which ensures adequate security of the systems or of data transfers.

- X.800 divides security services into five different categories :
 1. Authentication
 2. Access control
 3. Data confidentiality
 4. Data integrity
 5. Nonrepudiation.

1. Authentication :

- Authentication is the process of determining whether someone or something is, in fact, who or what it is declared to be. In public and private computer network, authentication is commonly done through the use of login passwords.
- Two specific authentication services are defined in X.800 :
 - a. Peer entity authentication
 - b. Data origin authentication
- **Peer entity authentication** used in association with a logical connection to provide confidence in the identity of the entities connected.
- **Data origin authentication** does not provide protection against the duplication or modification of data units. This type of service supports applications like electronic mail where there are no prior interactions between the communicating entities.

2. Access control :

- It is the ability to limit and control the access to host systems and applications via communications links.
- This service controls who can have access to a resource.

3. Data confidentiality :

- Confidentiality is the concealment of information or resources. It is the protection of transmitted data from passive attacks.
- Confidentiality is classified into,
 1. Connection confidentiality : The protection of all user data on a connection.
 2. Connectionless confidentiality : The protection of all user data in a single data block.
 3. Selective field confidentiality : The confidentiality of selected fields within the user data on a connection or in a single data block.
 4. Traffic flow confidentiality : The protection of the information that might be derived from observation of traffic flows.

4. Data Integrity :

- Integrity can apply to a stream of messages a single message or selected fields within a message.
- Modification causes loss of message integrity.
- Data integrity can be classified as,
 1. Connection integrity with recovery
 2. Connection integrity without recovery
 3. Selective field connection integrity
 4. Connectionless integrity
 5. Selective field connectionless integrity.
- Connection integrity with recovery provides for the integrity of all user data on a connection and detects any modification, insertion, deletion or reply of any data within an entire data sequence with recovery attempted.
- Connection integrity without recovery provides only detection without recovery.
- Selective field connection integrity provides for the integrity of selected fields within the user data of a data block transferred over a connection.
- Connectionless integrity provides for the integrity of a single connectionless data block and may take the form of detection of data modification.

5. Nonrepudiation :

- Nonrepudiation prevents either sender or receiver from denying a transmitted message.
- When a message is sent, the receiver can prove that the alleged sender in fact sent the message.
- When a message is received, the sender can prove that the alleged receiver in fact received the message.

6.4.1 OSI Security Architecture

- X.800 recommends sending architecture for OSI. The OSI security architecture define systematic way to asses security needs of on organization and help them to choose various security products and fields.

- The OSI security architecture mainly focuses on :

a) Security attack :

- Any action which comprises the organizaion secured information.

b) Security mechanism :

- A process designed to detect, prevent receiver from a security attack.

c) Security service :

- The security service are intended to counter security attack by making use of the one or more security mechanism.

6.5 Security Policy and Mechanism

- Security Policy is a statement of what is and what is not allowed
- Security mechanism is a method, tool, or procedure for enforcing a security policy.
- Security mechanisms can prevent the attack, detect the attack, or recover from the attack
- Mechanisms can be nontechnical, such as requiring proof of identity before changing a password; in fact, policies often require some procedural mechanisms that technology cannot enforce.
- Policies may be presented mathematically, as a list of allowed (secure) and disallowed (nonsecure) states.
- X.800 defined security mechanisms as follows :
 1. **Specific security mechanisms** : May be incorporated into the appropriate protocol layer in order to provide some of the OSI security services.
 - a. **Encipherment** : The use of mathematical algorithms to transform data into a form that is not readily intelligible.
 - b. **Digital signature** : Data appended to, or a cryptographic transformation of, a data unit that allows a recipient of the data unit to prove the source and integrity the data unit and protect against forgery.
 - c. **Access control** : A variety of mechanisms that enforce access rights to resources.
 - d. **Data integrity** : A variety of mechanisms used to ensure the integrity of a data unit or stream of data units.
 - e. **Authentication exchange** : A mechanism intended to ensure the identity of an entity by means of information exchange.

- f. **Traffic padding** : The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.
- g. **Notarization** : The use of a trusted third party to assure certain properties of a data exchange.
- 2. **Pervasive security mechanisms** : Mechanisms that are not specific to any particular OSI security service or protocol layer.
 - a. **Trusted functionality** : That which is perceived to be correct with respect to some criteria.
 - b. **Event detection** : Detection of security relevant events.
 - c. **Security label** : The marking bound to resource that names or designates the security attributes of that resource.
 - d. **Security recovery** : Deals with requests from mechanisms, such as event handling and management functions and takes recovery actions.

6.6 Operational Model of Network Security

- A message is to be transferred from source to destination across some sort of internet. Both the sides must cooperate for the exchange of the data.
- A logical information channel is established by defining a route through the internet from source to destination.
- All the techniques for providing security have two components :
 1. A security related transformation on the information to be sent.
 2. Some secret information shared by the two principles, it is hoped, unknown to the opponent.
- Fig. 6.6.1 shows the network security model.

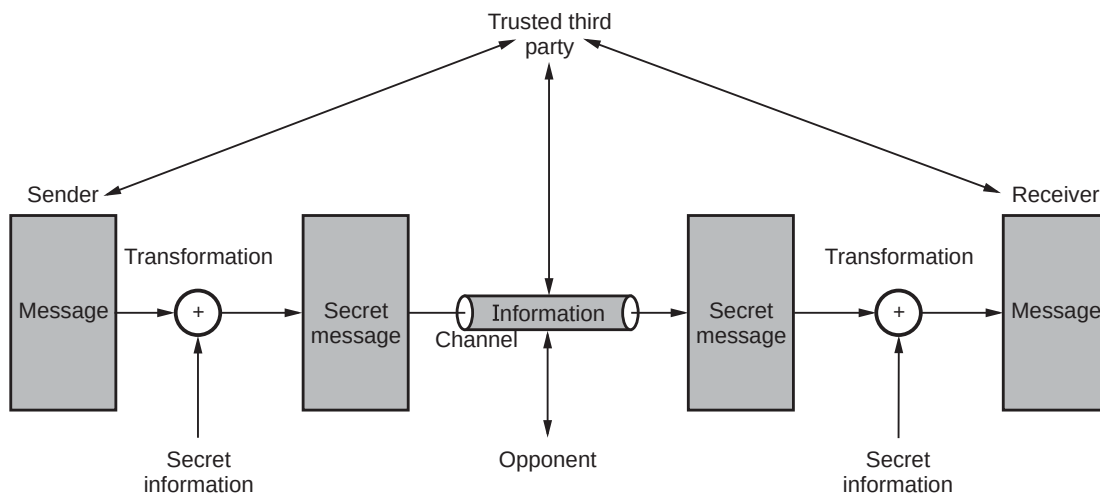


Fig. 6.6.1 Network security model

- A trusted third party is needed to achieve secure transmission.
- Basic tasks in designing a particular security service.
 1. Design an algorithm for performing the security related transformation.
 2. Generate the secret information to be used with the algorithm.
 3. Develop methods for the distribution and sharing of the secret information.
 4. Specify a protocol to be used by the two principles that makes use of the security algorithm and the secret information to achieve a particular security service.

6.7 Symmetric Key Cryptography

- A symmetric encryption model has five ingredients.
 1. Plaintext
 2. Encryption algorithm
 3. Secret key
 4. Ciphertext
 5. Decryption algorithm
- Fig. 6.7.1 shows the conventional encryption model.

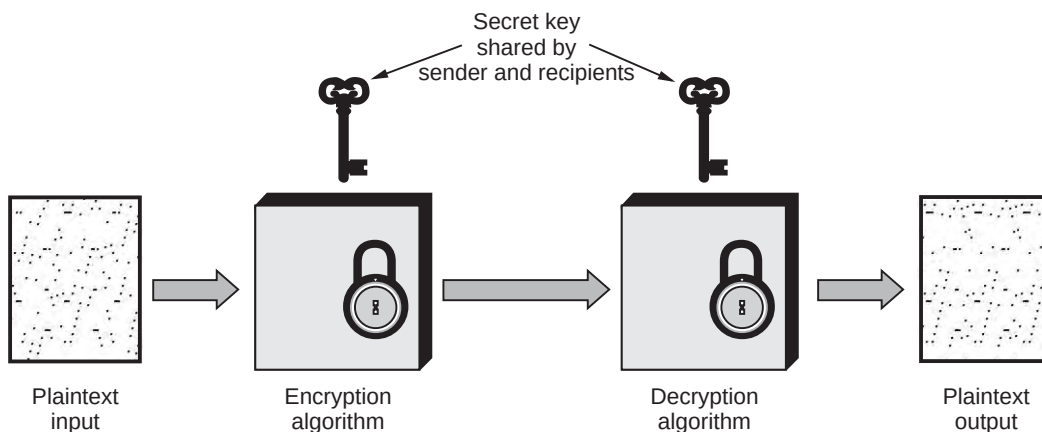


Fig. 6.7.1 Conventional encryption model

- **Plaintext** is the original message or data that is fed into the algorithm as input.
- **Encryption algorithm** performs various substitutions and transformations on the plaintext.
- **Secret key** is a value independent of the plaintext and of the algorithm. The exact substitutions and transformations performed by the algorithm depend on the key.
- **Ciphertext** is the scrambled message produced as output. It depends on the plaintext and the secret key.
- **Decryption algorithm** takes the ciphertext and the secret key and produces the original plaintext.

- The original intelligible message, referred to as plaintext is converted into random nonsense, referred to as ciphertext. The science and art of manipulating messages to make them secure is called **cryptography**.
- An original message to be transformed is called the plaintext, and the resulting message after the transformation is called the ciphertext.
- The process of converting the plaintext into ciphertext is called encryption. The reverse process is called decryption. The encryption process consists of an algorithm and a key. The key controls the algorithm.
- The objective is to design an encryption technique so that it would be very difficult or impossible for an unauthorized party to understand the contents of the ciphertext.
- A user can recover the original message only by decrypting the ciphertext using the secret key. Depending upon the secret key used, the algorithm will produce a different output. If the secret key changes, the output of the algorithm also changes.
- Fig. 6.7.2 shows the conventional encryption process.

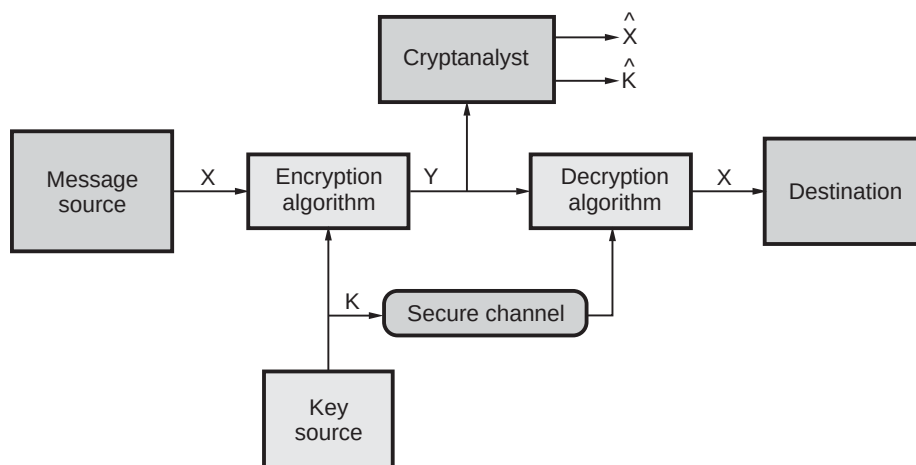


Fig. 6.7.2 Model of conventional cryptosystem

- The security of the conventional encryption depends on the several factors. The encryption algorithm must be powerful. Decryption message must be difficult. The algorithm depend on the secrecy of the key only. The algorithm is upon to all but only key is to keep secret. As shown in the diagram, the message source is the plaintext. i.e. X with the message X and encryption key K as input and ciphertext Y, we can write this as,

$$Y = E(K, X) \quad \dots(6.7.1)$$

- Using equation (6.7.1) Y is to be produced by using encryption algorithm E as a function of the plaintext X. The intended receiver in possession of the key, is able to invert the transformation.

$$X = D(K, Y) \quad \dots(6.7.2)$$

- An opponent, observing Y but not having access to K or X, must attempt to recover X and K or both X and K. It is assumed that the opponent does have knowledge of the encryption (E) and decryption (D) algorithms.

Characteristics of cryptography

- The type of operations used for transforming plaintext to ciphertext.
- The number of keys used.
- The way in which the plaintext is processed.

Cryptanalysis

- The process of trying to break any cipher text message to obtain the original plain text message itself is called as **cryptanalysis**.
- Cryptanalysis is the breaking of codes. The person attempting a cryptanalysis is called as a **cryptanalyst**.
- Brute force attack** : The attacker tries every possible key on a piece of cipher text until an intelligible translation into plaintext is obtained.

Types of attacks on encrypted messages

Sr. No.	Type of attack	Known to cryptanalyst
1.	Ciphertext only	1. Encryption algorithm 2. Ciphertext
2.	Known plaintext	1. Encryption algorithm 2. Ciphertext 3. One or more plaintext ciphertext pairs formed with the secret key.
3.	Chosen plaintext	1. Encryption algorithm 2. Ciphertext 3. Plaintext message chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key.
4.	Chosen ciphertext	1. Encryption algorithm 2. Ciphertext 3. Purported ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key.

5.	Chosen text	1. Encryption algorithm 2. Ciphertext 3. Plaintext message chosen by cryptanalyst, together with its corresponding ciphertext generated with the secret key. 4. Purported ciphertext chosen by cryptanalyst, together with its corresponding decrypted plaintext generated with the secret key.
----	-------------	---

The various type of cryptanalytic attacks based on the amount of information known to the cryptanalyst.

6.7.1 Advantages of Symmetric-key Cryptography

1. High rates of data throughput.
2. Keys for symmetric-key ciphers are relatively short.
3. Symmetric-key ciphers can be used as primitives to construct various cryptographic mechanisms (i.e. pseudorandom number generators).
4. Symmetric-key ciphers can be composed to produce stronger ciphers.
5. Symmetric-key encryption is perceived to have an extensive history.

6.7.2 Disadvantages of Symmetric-key Cryptography

1. Key must remain secret at both ends.
2. In large networks, there are many keys pairs to be managed
3. Sound cryptographic practices dictates that the key be changed frequently
4. Digital signature mechanisms arising from symmetric-key encryption typically require either large keys or the use of third trusted parties.

6.7.3 DES

- DES Encryption standard (DES) is a symmetric key block cipher published by the National Institute of Standards and Technology (NIST).
- It encrypts data in 64-bit block.
- DES is symmetric key algorithm : The same algorithm and key is used for both encryption and decryption.
- Key size is 56-bit.
- The encryption process is made of two permutations i.e. P-boxes, which is called **initial** and **final permutation**.
- DES uses both transposition and substitution and for that reasons is sometimes referred to as a product cipher. Its input, output and key are each 64-bits long. The sets of 64-bits are referred to as blocks.

- The cipher consists of 16 rounds or iterations. Each rounds uses a separate key of 48-bits.
- Fig. 6.7.3 shows DES encryption algorithm. First, the 64-bit plaintext passes an Initial Permutation (IP) that rearranges the bits of produce the permuted input.

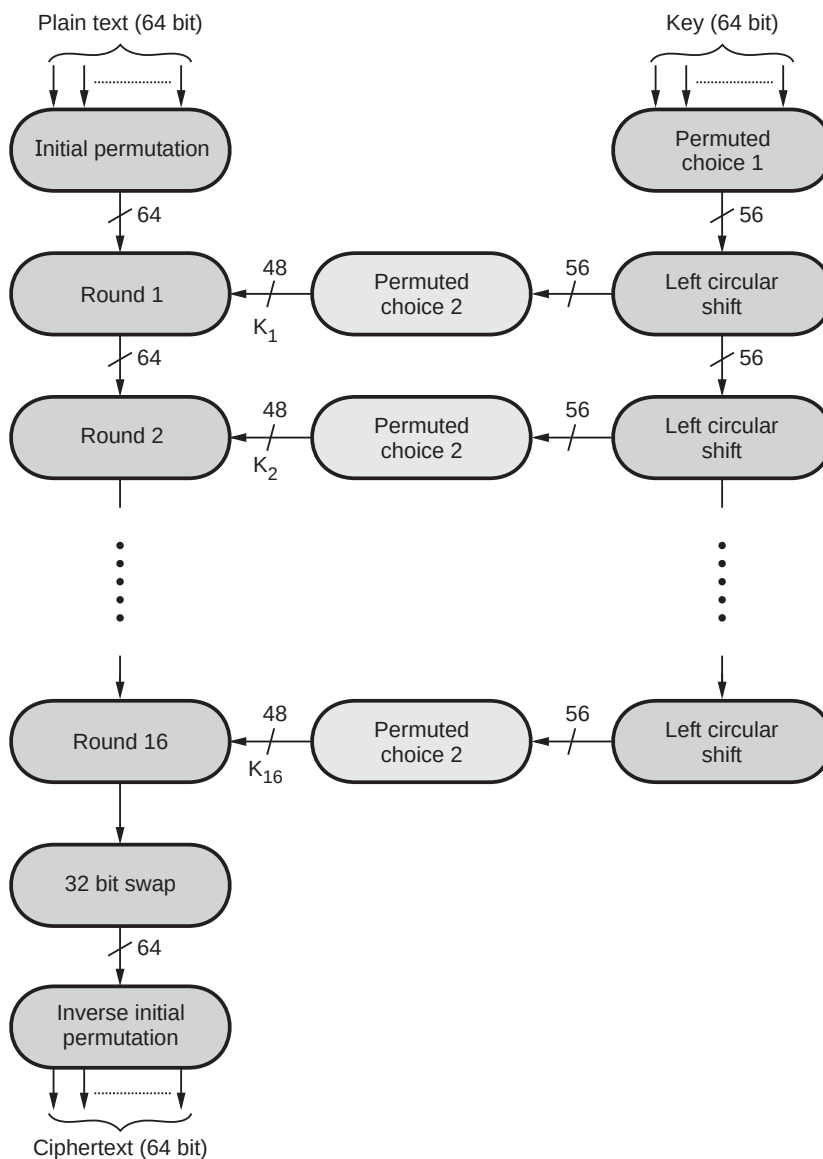


Fig. 6.7.3 DES encryption algorithm

- Then there is a phase consisting of 16 rounds of the same function, which involves both permutation and substitution functions.
- The output of the sixteenth round consists of 64-bits that are a function of the input plaintext and the key.

- A block to be enciphered is subjected to an initial permutation IP, then to a complex key-dependent computation and finally to a permutation which is inverse of the initial permutation IP.
- The key-dependent computation can be simply defined in terms of a function f , called the **cipher function** and a function KS, called the **key schedule**.
- The left and right halves of the output are swapped to produce the pre-output. At last, the pre-output is passed through a permutation (IP^{-1}) that is the inverse of the initial permutation function, to produce the 64-bit ciphertext.
- The overall processing at each round can be summarised in the following formulae :

$$L_i = R_{i-1}$$

$$R_i = L_{i-1} \times F(R_{i-1}, K_i)$$

- The left output (L_i) is simply copy of the right input (R_{i-1}). The right output (R_i) is the XOR of left input (L_{i-1}) and right input (R_{i-1}) and key for this stage is K_i . In this stage, the substitution and permutation both functions are used.
- Fig. 6.7.4 shows role of S-boxes in the function F. It consists of set of eight S-boxes, each of which accepts 6 bits input and produces 4 bits as output.

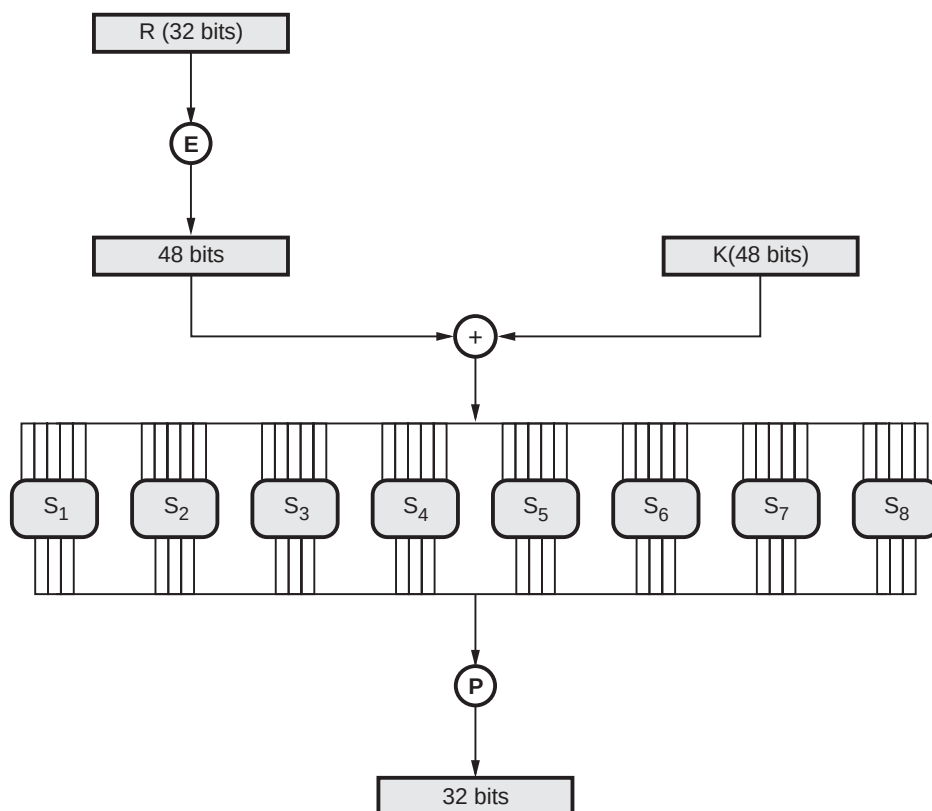


Fig. 6.7.4 S-boxes in the function (F)

- The 48 bit input block is divided into 8 subblocks and each subblock is given to a S-box. The S-box transforms the 6 bit input into a 4 bit output.
- First and last bits of the input to box S_i form a 2-bit binary number to select one of four substitutions defined by the four rows in the table for S_i . Two bits can store any decimal number between 0 and 3. This specifies the row number. The middle four bits select one of the sixteen columns.

Key generation :

- 64-bit key is used as input to the algorithm. The initial 64-bit key is transformed into a 56-bit key by discarding every 8th bit of the initial key.
- From 56-bit key, a different 48-bit subkey is generated during each round using a process called as **key transformation**.
- The resulting 56-bit key is then treated as two 28-bit quantities, labeled C_0 and D_0 . At each round, C_{i-1} and D_{i-1} are separately subjected to a circular left shift or rotation, of 1 or 2-bits.
- These shifted values serve as input to the next round. They also serve as input to Permuted choice Two, which produces a 48-bit output that serves as input to the function $F(R_{i-1}, K_i)$.

Advantages of DES :

1. As 56-bit keys are used there are 70 quadrillion possible key values and hence a specific key cannot be identified easily.
2. As the length of the key is increased the security provided by the algorithm also increases.
3. The security of the DES algorithm resides in the key.

Disadvantages of DES :

1. As it is a symmetric algorithm both sender and receiver must have same key, there is a possibility that the key is intercepted.
2. The design of S boxes makes it susceptible to linear cryptanalysis attack.
3. It is susceptible to differential cryptanalysis attack and brute force attack taking advantage of which DES crackers have been designed.
4. It has certain weak keys which generate the same key for all cycles of the algorithm like when all key bits are either 0s or 1s or if one half of the key bits are 0s or 1s. They are 0000000 0000000, 0000000 ffffffff, ffffffff 0000000, ffffffff ffffffff.
5. Some initial keys produce only two subkeys while some produce only four. They are called **possible weak keys**.

6.7.4 AES

- Advanced Encryption Standard (AES) is a symmetric key block cipher published by the NIST in December 2001.
- AES is a non-Feistel cipher that encrypts and decrypts a data block of 128-bits.
- The key size can be 128, 192 or 256-bits. It depends on number of rounds.
- The number of rounds : 10 rounds for 128-bits, 12 rounds for 192-bits and 14 rounds for 256-bits.

Characteristics :

1. Resistance against all known attacks.
2. Speed and code compactness on a wide range of platforms.
3. Design simplicity.
 - For 128-bits AES, each round contains four steps :
 - i. Byte substitution
 - ii. Row shift
 - iii. Column mixing
 - iv. Round key addition
 - The input to the encryption and decryption algorithms is a single 128-bit block. The block is represented as a row of matrix of 16 bytes.
 - AES use several rounds in which each round is made of several stages. Data block is transformed from one stage to another.
 - Data block is referred to as state. Block is copied into state array which is modified at each stage of encryption or decryption. After the final stage, state is copied to an output matrix.

6.7.5 Comparison between AES and DES

Sr. No.	Parameters	AES	DES
1.	Block size	128-bits	64-bits
2.	Key length	128, 192, 256-bits	56-bits (effective length)
3.	Encryption primitives	Substitution, shift, bit mixing	Substitution, Permutation
4.	Cryptographic primitives	Confusion, Diffusion	Confusion, Diffusion
5.	Design rationale	Closed	Open

6.8 Asymmetric Key Cryptography

- Diffie and Hellman proposed a new type of cryptography that distinguished between encryption and decryption keys. One of the keys would be publicly known; the other would be kept private by its owner.

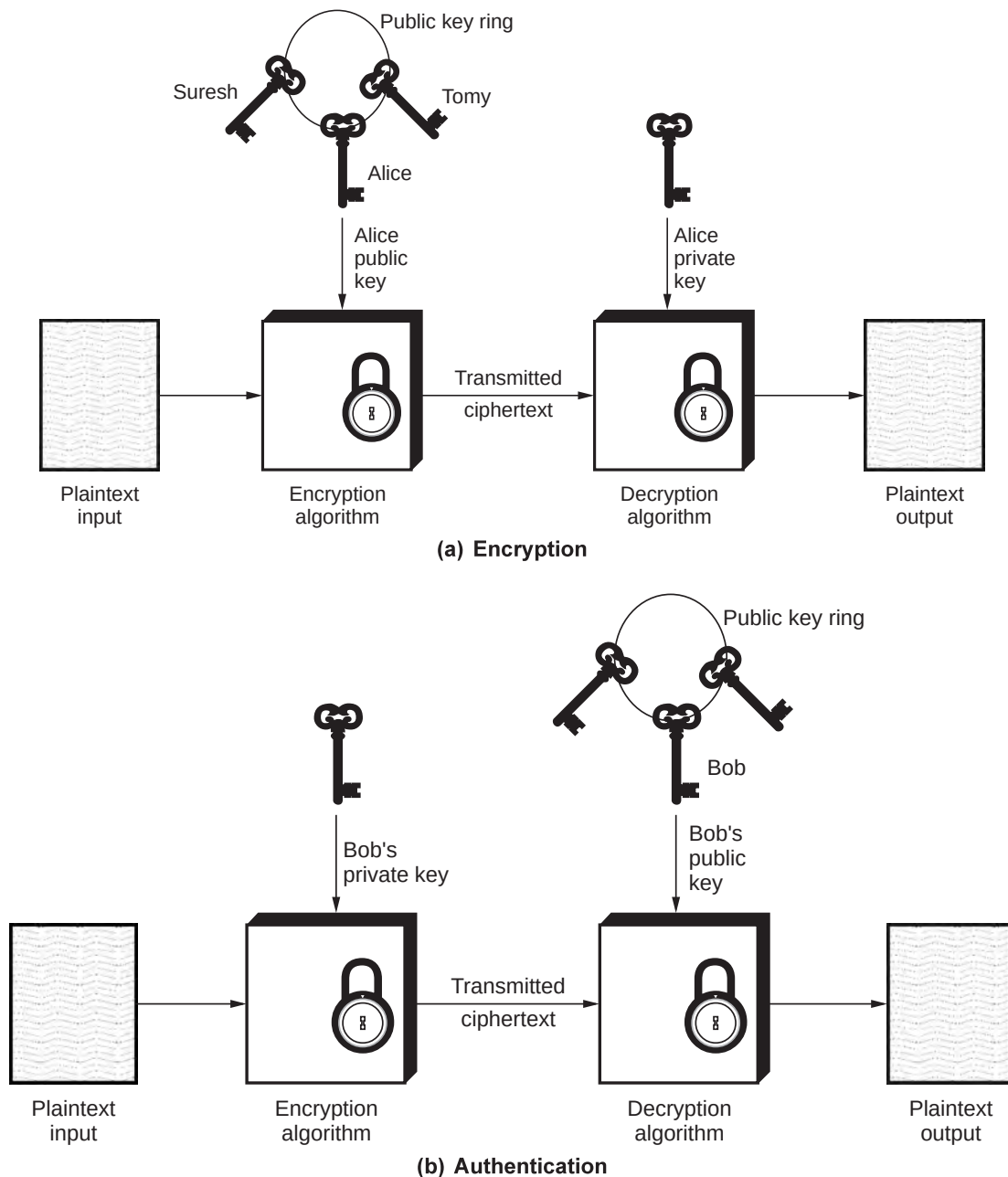


Fig. 6.8.1 Public key cryptography

- These algorithms have the following important **characteristic**.
 1. It must be computationally easy to encipher or decipher a message given the appropriate key.
 2. It must be computationally infeasible to derive the private key from the public key.
 3. It must be computationally infeasible to determine the private key from a chosen plaintext attack.
- A public key encryption scheme has six ingredients. Fig. 6.8.1 shows public key cryptography. (See Fig. 6.8.1 on previous page)
 1. **Plaintext** : It is input to algorithm and in a readable message or data.
 2. **Encryption algorithm** : It performs various transformations on the plaintext.
 3. **Public and private keys** : One key is used for encryption and other is used for decryption.
 4. **Ciphertext** : This is the scrambled message produced as output. It depends on the plaintext and the key.
 5. **Decryption algorithm** : This algorithm accepts the ciphertext and the matching key and produces the original plaintext.
- The essential steps are the following :
 1. Each user generates a pair of keys to be used for the encryption and decryption of messages.
 2. Each user places one of the two keys in a public register. This is the public key. The companion key is kept private.
 3. If Bob wishes to send a confidential message to Alice, Bob encrypts the message using Alice's public key.
 4. Alice decrypts the message using her private key.
- The public key is accessed to all participants and private key is generated locally by each participant.
- System controls its private key. At any time, a system can change its private key. Fig. 6.8.2 shows the process of public key algorithm. (See Fig. 6.8.2 on next page)
- A message from source which is in a plaintext, $X = (X_1, X_2, \dots, X_m)$. The message is intended for destination which generates a related pair of keys a public key KU_b , and a private key KR_b .
- Private key is secret key and known only to Y_1 . With the message X and encryption key KU_b as input, X_1 forms the ciphertext.

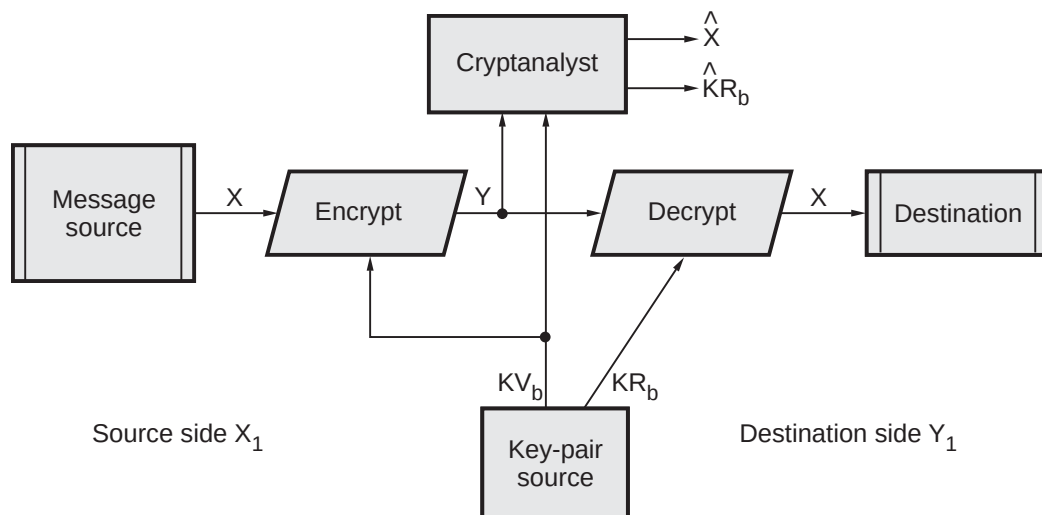


Fig. 6.8.2 Public key cryptosystem secrecy

$$Y = (Y_1, Y_2, Y_3 \dots Y_n)$$

$$Y = E_{KU_b}(X)$$

- The intended receiver, in possession of the matching private key is able to invert the transformation.

$$X = D_{KR_b}(Y)$$

- An opponent, observing Y and having access to public key (KU_b), but not having access to private key (KR_b), must attempt to recover X . It is assumed that the opponent does have knowledge of the encryption (E) and decryption algorithms (D).
- Public key cryptography requires each user to have two keys : A public key used by anyone for encrypting messages to be sent to that user and a private key, which the user needs for decrypting messages.

Requirements for public key cryptography

1. It is computationally easy for a party B to generate a pair.
2. It is computationally easy for a sender A, to generate the corresponding ciphertext :

$$C = E(PU_b, M)$$

3. It is computationally easy for the receiver B to decrypt the resulting ciphertext using the private key to recover the original message :

$$M = D(PR_b, C) = D[PR_b, E(PU_b, M)]$$

4. It is computationally infeasible for an adversary, knowing the public key (PU_b) to determine the private key PR_b .
5. It is computationally infeasible for an adversary, knowing the public key (PU_b) and a ciphertext (C) to recover the original message (M).

6.8.1 Advantages and Disadvantages

- **Advantages of public key algorithm**
 1. Only the private key must be kept secret.
 2. The administration of keys on a network requires the presence of only a functional trusted TTP as opposed to an unconditionally trusted TTP.
 3. A private/public key pair remains unchanged for considerable long periods of time.
 4. There are many relatively efficient digital signature mechanisms as a result of asymmetric-key schemes.
 5. In a large network the number of keys necessary may be considerably smaller than in the symmetric-key scenario.
- **Disadvantages of public key algorithm**
 1. Slower throughput rates than the best known symmetric-key schemes.
 2. Large key size.
 3. No asymmetric-key scheme has been proven to be secure.
 4. Lack of extensive history.

6.8.2 Comparison between Public Key and Private Key Algorithm

Sr. No.	Symmetric key cryptography	Asymmetric key cryptography
1.	Same key is used for encryption and decryption.	One key for encryption and other key for decryption.
2.	Very fast.	Slower.
3.	Key exchange is big problem.	Key exchange is not a problem.
4.	Also called secret key encryption.	Also called public key encryption.
5.	The key must be kept secret.	One of the two keys must be kept secret.
6.	The sender and receiver must share the algorithm and the key.	The sender and receiver must each have one of the matched pair of keys.
7.	Size of the resulting encrypted text is usually same as or less than the original clear text size.	Size of the resulting encrypted text is more than the original clear text size.
8.	Cannot be used for digital signatures.	Can be used for digital signature.

6.8.3 RSA

- RSA is a block cipher in which the plaintext and ciphertext are integers between 0 and $n - 1$ for some n .
- A typical size for n is 1024 bits.
- The RSA algorithm developed in 1977 by Rivest, Shamir, Adleman (RSA) at MIT. RSA algorithm is public key encryption type algorithm. In this algorithm, one user uses a public key and other user uses a secret (private key) key.
- In the RSA algorithm each station independently and randomly chooses two large primes p and q number, and multiplies them to produce $n = pq$ which is the modulus used in the arithmetic calculations of the algorithm.
- The details of the RSA algorithm are described as follows :
- **Key generation :**
 - 1) Pick two large prime numbers p and q , $p \neq q$;
 - 2) Calculate $n = p \times q$;
 - 3) Calculate $\phi(n) = (p - 1)(q - 1)$;
 - 4) Pick e , so that $\gcd(e, \phi(n)) = 1$, $1 < e < \phi(n)$;
 - 5) Calculate d , so that $d \cdot e \bmod \phi(n) = 1$, i.e. d is the multiplicative inverse of e in $\bmod \phi(n)$;
 - 6) Get public key as $K_U = \{e, n\}$;
 - 7) Get private key as $K_R = \{d, n\}$.
- **Encryption :**
For plaintext block $P < n$, its ciphertext $C = P^e \bmod n$.
- **Decryption :**
For ciphertext block C , its plaintext is $P = C^d \bmod n$.

Why RSA works :

- As we have seen from the RSA design, RSA algorithm uses modular exponentiation operation. For $n = p \cdot q$, e which is relatively prime to $\phi(n)$ has exponential inverse in $\bmod n$.
- Its exponential inverse d can be calculated as the multiplicative inverse of e in $\bmod \phi(n)$. The reason is illustrated as follows :
Based on Euler's theorem, for y which satisfies $y \bmod \phi(n) = 1$, the following equation holds :

$$x^y \bmod n = x \bmod n$$

As $d \cdot e \bmod \phi(n) = 1$, we have that $P^{ed} \equiv P \bmod n$. So the correctness of RSA cryptosystem is shown as follows :

- **Encryption** : $C = P^e \bmod n$;
- **Decryption** : $P = C^d \bmod n = (P^e)^d \bmod n = P^{ed} \bmod n = P \bmod n = P$.

Why RSA is secure :

- The premise behind RSA's security is the assumption that factoring a big number (n into p and q) is hard. And thus it is difficult to determine $\phi(n)$. Without the knowledge of $\phi(n)$, it would be hard to derive d based on the knowledge of e .

Advantages

1. RSA can be used both for encryption as well as for digital signatures.
2. Trapdoor in RSA is in knowing value of n but not knowing the primes that are factors of n .

Disadvantages

1. If any one of p , q , m , d is known, then the other values can be calculated. So secrecy is important.
2. To protect the encryption, the minimum number of bits in n should be 2048.

Example 6.8.1 For the given values $p = 19$, $q = 23$ and $e = 3$ find n , $\phi(n)$ and d using RSA algorithm.

Solution :

$$n = p * q$$

$$n = 19 \times 23$$

$$n = 437$$

$$\phi(n) = (p - 1) * (q - 1)$$

$$\phi(n) = 18 \times 22$$

$$\phi(n) = 396$$

$$e.d. = 1 \bmod \phi(n)$$

$$3d = 1 \bmod 396$$

$$d = \frac{1}{3}$$

Example 6.8.2 Using the RSA algorithm, encrypt the following :

- i) $p = 3$, $q = 11$, $e = 7$, $M = 12$
- ii) $p = 7$, $q = 11$, $e = 17$, $M = 25$
- iii) Find the corresponding d s for i) and ii) and decrypt the ciphertext.

Solution : i)

$$n = p * q$$

$$n = 3 * 11 = 33$$

$$\phi(n) = (p - 1) (q - 1)$$

$$\phi(n) = 2 * 10 = 20$$

$$e \cdot d = 1 \bmod \phi(n)$$

$$7 \cdot d = 1 \bmod 20$$

$$d = 3$$

$$\text{Ciphertext (C)} = M^e \bmod n$$

$$= 12^7 \bmod 33$$

$$C = 12$$

ii) $n = p * q = 7 * 11 = 77$

$$\phi(n) = (p - 1) * (q - 1) = 6 * 10 = 60$$

$$e \cdot d = 1 \bmod \phi(n) \Rightarrow 17 d = 1 \bmod 77$$

$$d = 3$$

$$\text{Ciphertext (C)} = M^e \bmod n$$

$$= 25^{17} \bmod 77 \Rightarrow 77 \Rightarrow c = 9$$

$$C = 12$$

iii) Decryption :

$$M = c^d \bmod n$$

In case (i) $M = 12^3 \bmod 33 = 12$

In case (ii) $M = 9^{57} \bmod 77 = 25$

Example 6.8.3 In RSA system the public key of a given user is $e = 7$ and $n = 187$

i) What is the private key of this user ?

ii) If the intercepted ciphertext is $c = 11$ and sent to a user whose public key is $e = 7$ and $n = 187$. What is the plaintext ?

iii) What are the possible approaches to defeating the RSA algorithm ?

Solution : i) $n = p * q$

$$n = 11 * 17 \Rightarrow 187$$

$$\phi(n) = (p - 1) (q - 1)$$

$$= (17 - 1) (11 - 1) = 16 * 10 = 160$$

$$e \cdot d = 1 \bmod \phi(n)$$

$$7d = 1 \bmod 160$$

$$7 \times 23 = 1 \bmod 160$$

Public key PU (e, n) = 7, 187

Private key PR (d, n) = 23, 187

ii) $c = 11, e = 7, n = 187$

$$\begin{aligned}\text{Plaintext } p &= c^d \bmod n \\ &= 11^{23} \bmod 187 \\ &= 79720245 \bmod 187\end{aligned}$$

$\therefore$ Plaintext = 88

6.9 Security in Network, Transport and Application Layer

- At the data link and network layers, the security framework protects systems with a number of technologies. VPNs protect information by encrypting it and sending it through encrypted tunnels through network or the internet. Network intrusion detection systems or NIDS watch traffic flowing over the wires looking for bit stream patterns that could indicate attacks or malicious intent.
- Host intrusion detection systems monitor bit streams entering the host machines at the Network Interface Card (NIC) level, also looking for suspicious patterns. Virus scanning at this level looks for patterns that indicate malicious code that fits signatures for known **viruses**.
- At the network and transport layer, the security framework uses firewalls to do careful inspection of packets entering and leaving the network. Routers, using Access Control Lists or ACLs filter IP packets, preventing traffic from going to systems that have no need for it.
- Utilizing IP address schemes, network engineers can plan and implement routing tables that protect networks with router ACLs, making firewall rules easier to write and deploy and thwarting attacks such as address spoofing. At the network and transport layers, virus scanning software opens attachments in messaging packets such as e-mail, looking for embedded viruses or malicious code.
- At the session, presentation and application layers, the security framework uses a number of techniques and tools to secure systems. Some of these techniques are policies for system management such as hardening the operating systems, keeping patch levels and OS revisions up to date, running with only the service needed to support the business processes and turning off all other process, running processes with limited system privileges, etc.

- All of these management techniques contribute to security at the session, presentation and application layer and are the kind of system controls that automatically enforce security policies.
- At the presentation and application layers, the security framework utilizes user account management to control access to the network, systems and applications. The security framework relies on system managers to control access to their machines, network administrators to manage user access to their networks and application managers such as Data Base Administrators (DBA) to control access to applications and data.
- At this level, the security framework includes virus scanning applications to scan hard drives and system memory for malicious code, updating scan engines and virus signatures. Host Intrusion Detection Systems (HIDS), active in the lower levels of the model, work at the presentation and application layer to watch for changes to critical system files and other system behaviour that might indicate an attacker trying to gain control of the system.
- The security framework can also control user access centrally using a role/rule-based access control (RBAC) engine, that uses a directory such as LDAP or Active Directory that contains information about users and the systems and resources to which the users are authorized access. PKI and digital certificates can be used at this level to provide digital signatures, encryption and non-repudiation at the application level.

6.9.1 Introduction of IPSec

- Different application specific security mechanisms are developed such as electronic mail (PAG, S/MIME), client/server (Keyberos), web access (secure sockets layers). An IP level security can ensure secure networking not only for applications with security mechanisms but also for many security ignorant applications.
- IP Security (IPSec) is the capability that can be added to present versions of Internet protocol (IPv4 and IPv6) by means of additional headers for secure communication across LAN, WAN and Internet.
- IPsec is a set of protocols and mechanism that provide confidentiality authentication, message integrity and replay detection at IP layer. The device (firewall or gateway) on which the IPSec mechanism reside is called as **security gateway**.
- IPSec has two modes of operation.
 1. Transport mode
 2. Tunnel mode.

- IPSec uses two protocols for message security.
 1. Authentication Header (AH) protocol.
 2. Encapsulating Security Payload (ESP) protocol.
- IPSec mechanism uses Security Policy Database (SPD) which determines how a messages are to handle also the security services needed and path the packet should take.
- Various documents are used to define complex IPSec specification. The overall architecture of IPSec is constituted by three major components.
 1. IPSec documents
 2. IPSec services
 3. Security Associations (SA).
- IPSec provides security services at IP layer by selecting required security protocols, algorithms and cryptographic keys as per the services requested.
- Two protocols performs the function of providing security. These are authentication header protocol and protocol for encapsulating security payload.

Transport Mode :

- AH and ESP can support two modes of operation,
 1. Transport mode
 2. Tunnel mode.
- Transport mode mainly provide protection for upper layer protocols. The protection extends to the payload of an IP packet. For example, TCP or UDP segment or ICMP packet.
- The transport mode is suitable for end-to-end communication between two workstations.
- In transport mode, ESP encrypts the IP payload excluding IP header. authentication of IP payload and specific portions of IP header.

Tunnel Mode :

- Tunnel mode provides protection to entire IP packets. Security fields are added to IP packets and entire packet (AH or ESP packet + Security packet) is new IP packet with a new IP header.
- Entire new IP packet travels through a tunnel from one point to other over IP network. No router over the network are able to detect inner IP header. Since original packet is encapsulated by new larger packet having different source and destination address.
- Tunnel mode is preferred when one or both ends of an SA a security gateway such as a firewall or router that implements IPSec.

- In tunnel mode, number of hosts on network with firewalls may engage in secure transmission without IPSec. The unsecured packets generated are tunneled through external networks by tunnel mode SAs or IPSec in firewall or router.
- ESP encrypts and optionally authenticates the entire inner IP packet including IP header.
- AH authenticates the entire inner IP packet and selected portion of outer IP header.

Benefits of IPSec :

1. IPSec provides strong security within and across the LANs.
2. IPSec in a firewall avoids bypass if all traffic from the outside must use IP.
3. No need to change software for implementing IPSec.
4. IPSec is below transport layer and hence is transparent to applications.
5. IPSec is transparent to end users also.
6. If required IPSec can provide security to individual users.

6.10 Secure Socket Layer

- SSL protocol is an internet protocol for secure exchange of information between a web browser and a web server.
- SSL is designed to make use of TCP to provide a reliable end to end secure service.
- Secure Socket Layer (SSL) provides security services between TCP and applications that use TCP. The SSL protocol is an internet protocol for secure exchange of information between a web browser and a web server.

Features of SSL

1. SSL server authentication, allowing a user to confirm a server's identity.
2. SSL client authentication, allowing a server to confirm a user's identity.
3. An encrypted SSL session, in which all information sent between browser and server is encrypted by a sending software and decrypted by the receiving software.
4. SSL supports multiple cryptographic algorithms.

6.10.1 SSL Architecture

- SSL uses TCP to provide reliable end-to-end secure service. SSL consists of two subprotocols, one for establishing a secure connection and other for using it. Fig. 6.10.1 shows SSL protocol stack.

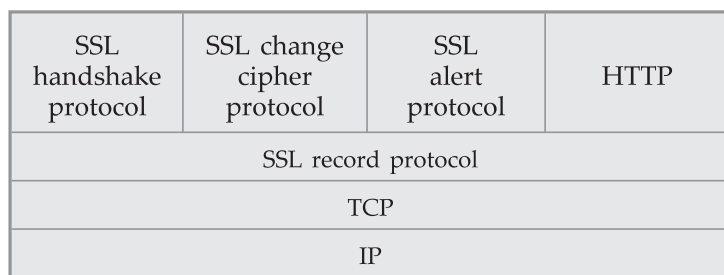


Fig. 6.10.1 SSL protocol stack

SSL record protocol : It provides basic security services to various higher layer protocols

HTTP : Provides the transfer service for web client/server interaction.

SSL Handshake protocol,

SSL Change cipher protocol, : Management of SSL exchanges.

SSL Alert protocol.

6.10.2 SSL Record Protocol

- The SSL Record protocol provides two services for SSL connection.

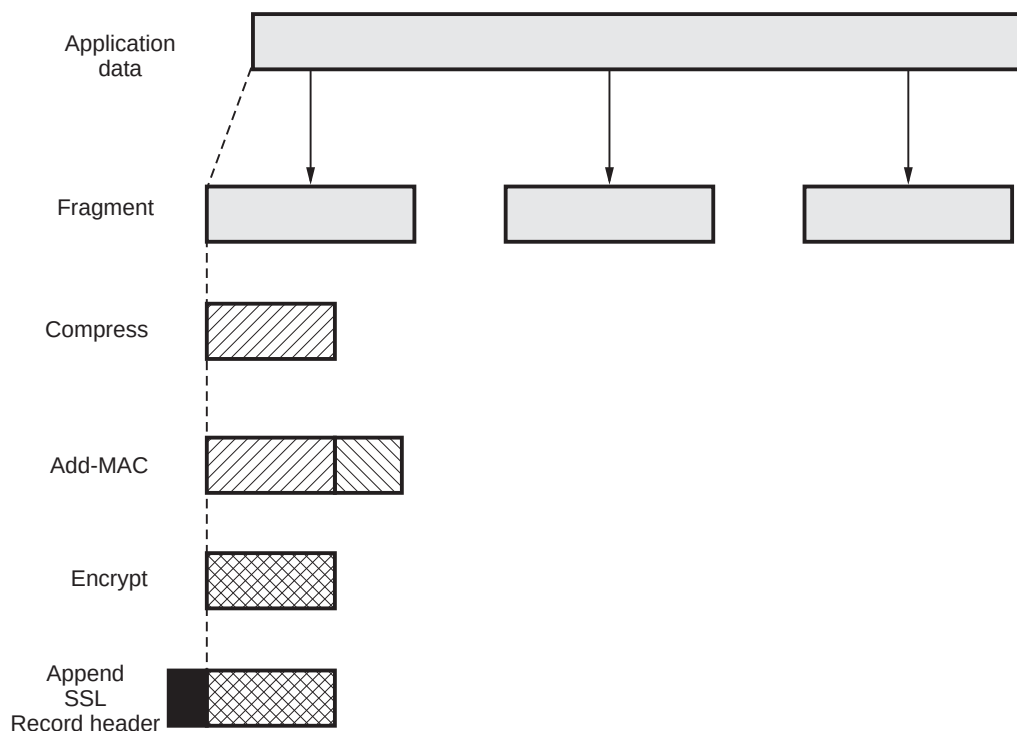


Fig. 6.10.2 SSL Record protocol operation

1. **Confidentiality** - Handshake protocol for encryption of SSL payload.
 2. **Message integrity** - Handshake protocol for Message Authentication Code (MAC).
- SSL record protocol operation is shown in Fig. 6.10.2. (See Fig. 6.10.2 on previous page.)
 - The record protocol takes application message to transmit, fragments the data, compress, applies MAC, encrypts, adds a header and transmits the TCP segment.

6.10.3 Handshake Protocol

- Handshake protocol allows the server and client to authenticate each other and to negotiate an encryption before transmitting application data various messages are used in protocol. Table 6.10.1 enlist these messages and there associated function.

Phase	Message type	Function
1.	Hello - request Client - hello Server - hellow	Null Version, session id, cipher, compression Version, session id, cipher, compression.
2.	Certificate Server - key - exchange Certificate - request Server - done	Chain of X.509 V3 certificates. Parameters, signature. Type, authorities. Null
3.	Certificate - verify	Signature
4.	Client - key - exchange finished.	Parameters, signature hash value.

Table 6.10.1 SSL handshake protocol message types

- Fig. 6.10.3 shows handshake protocol action.

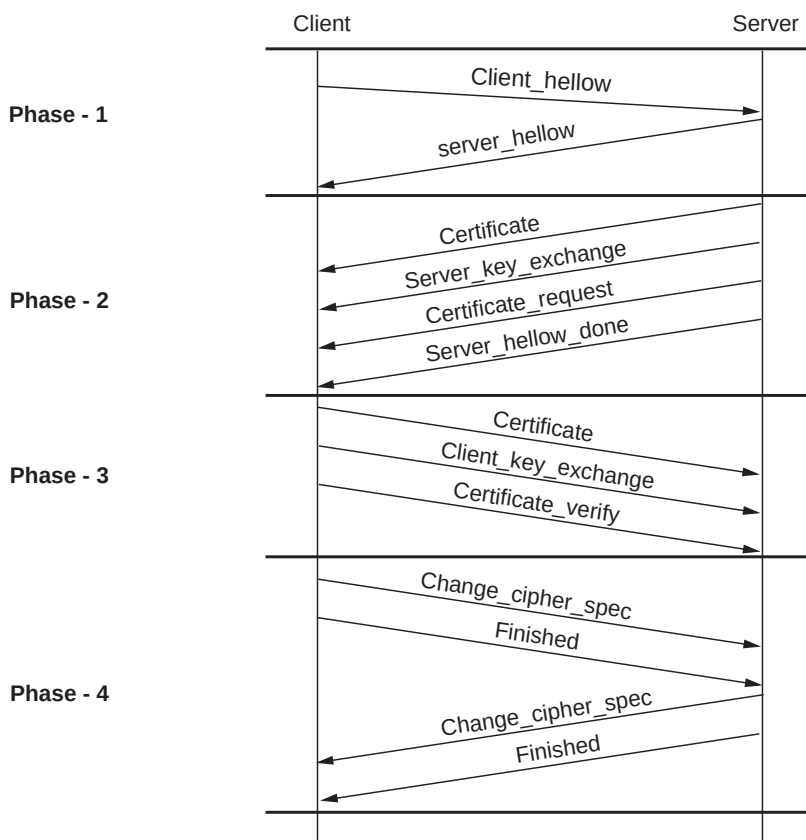


Fig. 6.10.3 Handshake protocol action

6.10.4 Comparison between IPSec and SSL

Sr. No.	Parameters	IPSec	SSL
1.	Position in the OSI model	Internet Layer	Between transport and application layers
2.	Configuration	Complex	Simple
3.	NAT	Problematic	No Problem
4.	Software Location	Kernel Area	User Area
5.	Firewall	Not Friendly	Friendly
6.	Installation	Vender Non-specific	Vender Specific
7.	Interoperability	Yes	No
8.	Deploy	More expensive to deploy, support and maintain.	Less costly to deploy and maintain

6.10.5 Comparison of SSL and TLS

SSL	TLS
In SSL the minor version is 0 and the major version is 3.	In TLS, the major version is 3 and the minor version is 1.
SSL use HMAC algorithm except that the padding bytes concatenation.	TLS makes use of the same algorithm the padding bytes concatenation.
SSL supports 12 various alert codes.	TLS supports all of the alert codes defined in SSL 3 with the exception of no certificate.

6.11 HTTPS

Secure HTTP is an extension to the Hypertext Transfer Protocol (HTTP) that allows the secure exchange of files on the World Wide Web.

- In HTTP basic authentication, the client sends his username and password in clear text as part of the HTTP request.
- In all subsequent HTTP requests for content from subdirectories of the original request, these credentials will be automatically resent.
- In HTTP digest authentication, no passwords are sent in the clear. Instead, a cryptographic hash value containing the username, password and additional security-relevant data, will be transmitted from the client to the server.

HTTP Problems :

1. HTTP basic authentication is vulnerable to passive eavesdropping. Moreover, it provides no mechanism for explicit session expiration (i.e. logout).
 2. HTTP digest authentication cannot guarantee sufficient support on all client platforms.
 3. Both mechanisms do not provide session tracking but only authentication.
- Secure HTTP indicates to user that page contents were not viewed or modified by a network attacker.
 - Each S-HTTP file is either encrypted, contains a digital certificate or both. For a given document, S-HTTP is an alternative to another well-known security protocol, Secure Sockets Layer (SSL).
 - A major difference is that S-HTTP allows the client to send a certificate to authenticate the user whereas, using SSL, only the server can be authenticated. S-HTTP is more likely to be used in situations where the server represents a bank and requires authentication from the user that is more secure than a user-id and password.
 - Fig. 6.11.1 shows position of HTTPS.

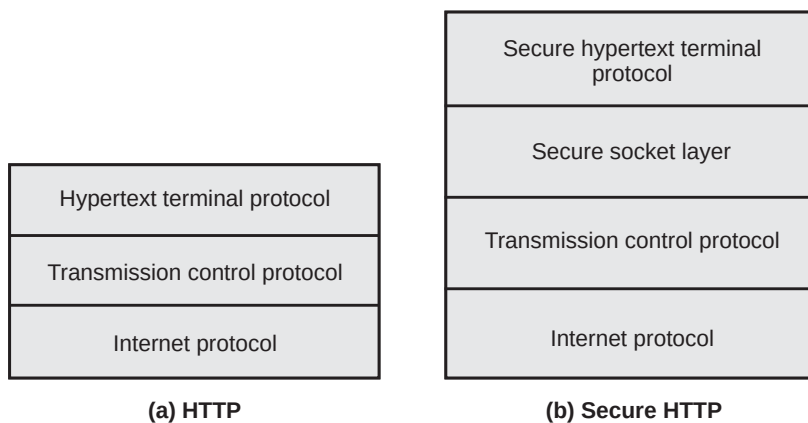


Fig. 6.11.1 Position of secure HTTP

- Secure HTTP layer is above the SSL and TCP protocol. HTTPS communicates over port 443 by default.
- Fig. 6.11.2 shows secure HTTP transactions.

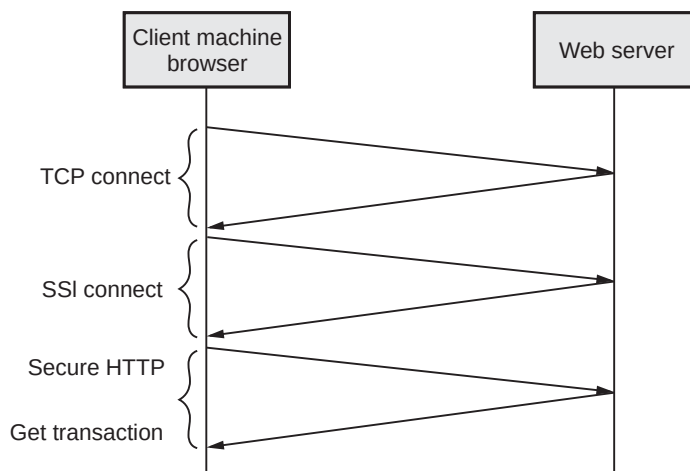


Fig. 6.11.2 HTTPS transaction

- When a client makes a request over HTTPS, it first tries to locate a certificate on the server. If the cert is found, it attempts to verify it against its known list of Certificate Authorities (CA). If it is not one of the listed CAs, it might show a dialog to the user warning about the website's certificate. Once the certificate is verified, the SSL handshake is complete and secure transmission is in effect.
- Benefits of a HTTPS certificate are :
 - Customer information like credit card numbers, bank account numbers is encrypted and cannot be intercepted.

2. Visitors can verify.
 3. Customers are more likely to trust and complete purchases from sites that use HTTPS.
- S-HTTP provides a wide variety of mechanisms of provide for confidentiality, authentication and integrity. It also includes header definitions to provide key transfer, certificate transfer and similar administrative functions.
 - S-HTTP does not use any a particular key certification scheme. It includes support for RSA, in-band, out-of-band and Kerberos key exchange. Like SLL, client public keys are not required.

6.12 S / MIME

- S/MIME is a Secure / Multipurpose Internet Mail Extension. It is a security enhancement to the MIME Internet e-mail format standard.
- RFC 822 defines a format for text messages that are sent using electronic mail. The RFC 822 standard applies only to the contents.
- MIME is an extension to the RFC 822 framework that is intended to address some of the problems and limitations of the use of SMTP.
- **SMTP limitations :**
 1. SMTP cannot transmit executable files or binary objects.
 2. SMTP cannot transmit text data that includes national language characters.
 3. SMTP servers may reject mail message over a certain size.
 4. SMTP gateways to X.400 electronic mail networks cannot handle nontextual data included in X.400 messages.
 5. SMTP gateways that translate between ASCII and the character code EBCDIC do not use a consistent set of mappings, resulting in translation problems.

Function of S/MIME :

- **Functions** are as follows
 1. Enveloped data
 2. Signed data
 3. Clear signed data
 4. Signed and enveloped data.
- **Enveloped data** consists of encrypted content of any type and encrypted content encryption key for one or more recipients.
- A **singed data** message can only be viewed by a recipient with S/MIME capability. Base64 encoding method is used for encoding content and signature.

- In **clear signed data**, a digital signature of the content is formed. Here only the digital signature is encoded using base64. Recipients without S/MIME capability can view the message content, although they cannot verify the signature.
- **Signed and enveloped data** : Signed only and encrypted only entities may be nested, so that encrypted data may be signed and signed data or clear signed data may be encrypted.

Cryptographic Algorithms in S/MIME

- S/MIME incorporates three public key algorithms.
 1. Digital signature standard
 2. Diffie-Hellman
 3. Triple DES.
- RFC 2119 specify the requirement level for S/MIME.
 1. MUST
 2. SHOULD.
- **MUST** : The definition is an absolute requirement of the specification. An implementation must include this feature or function to be in conformance with the specification.
- **SHOULD** : There may exist valid reasons in particular circumstances to ignore this feature or function, but it is recommended that in implementation include the feature or function.

S/MIME Messages :

General procedures for S/MIME message preparation.

1) Securing a MIME Entity :

- It secures a MIME entity with a signature, encryption or both.
- A MIME entity may be an entire message or if the MIME content type is multipart, then a MIME entity is one or more of the supports of the message.
- The MIME entity is prepared according to the normal rules for MIME message preparation.
- PKCS object is prepared by using MIME entity plus some security related data. Security related data item consists of an algorithm identifiers and certificates.
- The message to be send is converted to canonical form in all cases. For multipart message, the appropriate canonical form is used for each subpart.

2) Enveloped Data :

- Steps for preparing an enveloped data
 1. Generate a psedorandom session key for a particular symmetric encryption algorithm.

2. For each recipient, encrypt the session key with the recipient's public. RSA key.
3. Prepare a block for each recipient. Block is known as RecipientInfo which contains the sender public key certificate, an identifier of the algorithm used to encrypt the session key and the encrypted session key.
4. Encrypt the message content with the session key.

3) Signed data :

- Steps for preparing signed data are,
 1. Select a message digest algorithm i.e. SHA or MD5.
 2. Compute the message digest or hash function of the content to be signed.
 3. Encrypt the message digest with the signer's private key.
 4. Prepare a block known as signerInfo. SignerInfo contains the signer's public key certificate, an identifier of the message digest algorithm, an identifier of the algorithm used to encrypt the message digest.

4) Clear signing :

- Clear signing is achieved using the multipart content type with a signed subtype. Message is sent "in the clear" because recipient with MIME capability but not S/MIME capability are able to read the incoming message.
- A multipart / signed message has two parts.
 1. MIME type
 2. MIME content type
- If the first part is not 7 bit, then it needs to be encoded using base 64 or quoted printable.
- Second part has a MIME content type of application and a subtype of PKCS7 signature.

5) Registration request :

- The certification request includes,
 - a. Certification RequestInfo block
 - b. Identifier of the public key encryption algorithm
 - c. Signature of the certification RequestInfo block.
- The certification RequestInfo block includes a name of the certificate subject and a bit-string representation of the users public key.

6.13 Overview of IDS

- An intruder is a person who attempts to gain unauthorized access to a system, to damage that system or to disturb data on that system.

- Three classes of intruders are Masquerader, Misfeasor and Clandestine user.
 1. **Masquerader** : An unauthorized user who penetrates a computer system's access control and gains access to user accounts.
 2. **Misfeasor** : A legitimate user who accesses resource he is not authorized to access. Who is authorized such access but misuses his privileges.
 3. **Clandestine user** : A user who seizes the supervisory control of the systems and uses it to evade auditing and access control.
- **Intrusion** is the act of gaining unauthorized access to a system so as to cause loss.
- **Intrusion detection** is the act of detecting unwanted traffic on a network or a device.
- Intrusion Detection Systems (IDSs) attempt to identify attacks by comparing collected data to predefined signatures known to be malicious or to a model of legal behavior.
- Intrusion detection systems are software or hardware systems that automate the process of monitoring the events occurring in a computer system or network, analyzing them for signs of security problems.

Functions of intrusion detection systems :

1. Monitoring and analysis of user and system activity
2. Auditing of system configurations and vulnerabilities.
3. Assessing the integrity of critical system and data files.
4. Recognition of activity patterns reflecting known attacks.
5. Statistical analysis for abnormal activity patterns.

6.13.1 Types of Intrusion Detection System

1) Anomaly detection :

- An anomaly based intrusion detection system is a system for detecting computer intrusions and misuse by monitoring system activity and classifying it as either normal or anomalous.
- It examines ongoing traffic, activity, transactions and behaviour in order to identify intrusions by detecting anomalies.
- For instance, anomaly-based IDS will detect that an IP packet is malformed. It does not detect that it is malformed in a specific way, but indicates that it is anomalous.

2) Signature based :

- A signature based IDS will monitor packets on the network and compare them against a database of signatures or attributes from known **malicious threats**.

- This is similar to the way most antivirus software detects malware.
- A common strategy for IDS in detecting intrusions is to memorize signatures of known attacks. The inherent weakness in relying on signatures is that the signature patterns must be known first.

Advantages of signature-based detection :

1. Signatures are easy to develop
2. Understand if you know what network behavior you're trying to identify.

Disadvantages of signature-based detection :

1. High false positive rate
2. Largely ineffective at detecting previously unknown threats
3. Signature database must be continually updated and maintained.

3) Network based :

- A Network Intrusion Detection System (NIDS) is tries to detect malicious activity such as denial of service attacks; port scans or even attempts to crack into computers by network security monitoring of network traffic.
- Network intrusion detection systems are placed at a strategic point or points within the network to monitor traffic to and from all devices on the network.
- The majority of commercial intrusion detection systems are network based.
- These IDSs detect attacks by capturing and analyzing network packets.

Advantages of network-based IDSs :

1. A few well-placed network-based IDSs can monitor a large network.
2. The deployment of network-based IDSs has little impact upon an existing network.
3. It can be made very secure against attack.

Disadvantages of network-based IDSs :

1. Network-based IDSs may have difficulty processing all packets in a large or busy network.
2. Network-based IDSs cannot analyze encrypted information.
3. Most network-based IDSs cannot tell whether or not an attack was successful.
4. Some network-based IDSs have problems dealing with network-based attacks that involve fragmenting packets.

4) Host-based :

- Host based monitors system logs for evidence of malicious or suspicious application activity in real time.
- It requires small programs or agents to be installed on individual systems to be monitored. The agents supervise the OS and write data to log files and activate alarm.
- Host-based IDSs operate on information collected from within an individual computer system.
- This allows host-based IDSs to analyze activities with great reliability and precision, determining exactly which processes and users are involved in a particular attack on the operating system.
- Host-based IDSs normally utilize information sources of two types, operating system audit trails and system logs.

Advantages :

1. With their ability to monitor events local to a host, can detect attacks that cannot be seen by network-based IDS.
2. It can often operate in an environment in which network traffic is encrypted.
3. When host-based IDSs operate on OS audit trails; they can help detect Trojan horse or other attacks that involve software integrity breaches.

Disadvantages :

1. Host-based IDSs are harder to manage, as information must be configured and managed for every host monitored.
2. Since at least the information sources for host-based IDSs reside on the host targeted by attacks, the IDS may be attacked and disabled as part of the attack.
3. Host-based IDSs are not well suited for detecting network scans or other such surveillance that targets an entire network.
4. Host-based IDSs can be disabled by certain denial-of-service attacks.

6.13.2 Benefits of Intrusion Detection

1. Improving integrity of other parts of the information security infrastructure
2. Improved system monitoring
3. Tracing user activity from the point of entry to point of exit or impact.
4. Recognizing and reporting alterations to data files.
5. Spotting errors of system configuration and sometimes correcting them.

6. Recognizing specific types of attack and alerting appropriate staff for defensive responses.
7. Keeping system management personnel up to date on recent corrections to programs.
8. Allowing non-expert staff to contribute to system security.
9. Providing guidelines in establishing information security policies.

6.14 Firewalls

- Information systems in an organization have changed vary rapidly over the years from centralized data processing, LANs, WANs and Internet connectivity.
- The Internet connectivity is essential for the organization enabling access to outside world. Also it is a threat to the organization if not secured from intrusions (unauthorized access/users).
- A firewall is inserted between the Internet and LAN for security purpose. The firewall protects the LAN from Internet-based attacks and also provides security and audits.
- A firewall may be a hardware or a software program running on a secure host computer. A firewall is placed at junction or gateway between the two networks.
- A firewall must have at least two network interfaces one for the network it is intended to protect and one for the network and other for the network it is exposed to. A firewall placed between a private or corporate network and a public network (Internet) is shown in Fig. 6.14.1.

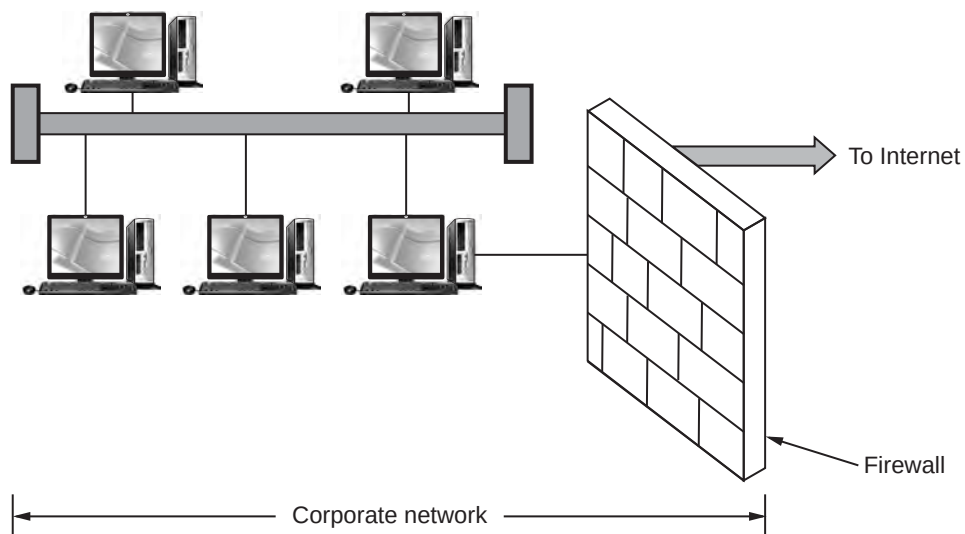


Fig. 6.14.1 Firewall

- The term firewall comes from the fact that by segmenting a network into different physical subnetwork, they limit the damage that could spread from one subnet to other just like firedoors or firewalls.

Capabilities of firewall

- A firewall examines all traffic routed between the two networks to see if it meets the certain criteria. If it does, it is routed between the networks, otherwise it is stopped.
- A firewall filters both inbound and outbound traffic. It can also manage public access to private networked resources such as host applications. It can be used to log all attempts to enter the private network and trigger alarms when hostile or unauthorized entry is attempted.
- Firewalls can filter packets based on their source and destination addresses and port numbers. This known as **address filtering**.
- Firewalls can also filter specific types of network called **protocol filtering** because the decision to forward or reject traffic is dependent upon the protocol used. For example, HTTP,FTP, Telnet.
- Firewalls can also filter traffic by packet attribute or state.

Limitations of firewall

- A firewall cannot prevent individual users with modems from dialing into or out of the network, by passing the firewall altogether.
- Employee misconduct or carelessness cannot be controlled by firewalls.
- Policies involving the use and misuse of passwords and user accounts must be strictly enforced. These are management issues that should be raised during the planning of any security policy but that cannot be solved with firewalls alone.

Firewall technology

- Firewall technology generally falls into one of the two categories. Network level and application level.
 - 1. Network level :** This guards the entire network from unauthorised intrusion. An example of this technology is packet filtering, which simply reviews all information coming into a network and rejects the data that does not meet a predefined set of criteria.
 - 2. Application level :** This technology controls access on an application by application basis. For example, proxy servers can be set up to permit access to some application, such as HTTP, while blocking access to others, such as FTP.

Design goals

- Firewalls are very effective means for network based security threats. The design goals for firewall are as under,
 1. All the traffic must pass through firewall both from inside to outside and outside to inside.
 2. Only authorized traffic defined by local security is allowed to pass.
 3. Firewall itself is immune to penetration.
 - Generally four techniques are used to control access and enforce the security policy, these techniques are -
 1. Service control
 2. Direction control
 3. User control
 4. Behavior control.
1. **Service control** : • Service control determines the types of Internet services that are allowed to access both inbound and outbound traffic.
 - The firewall may filter the traffic on the basis of IP address and TCP port number. The firewall provide proxy software to receive and interpret each service request before passing it on.
 2. **Direction control** : • Direction control determines the direction in which particular service requests may be initiated and is allowed to flow through the firewall.
 3. **User control** : • User control gives access to a service according to which user is attempting to access it. This feature is usually applied for local user inside the firewall perimeter.
 4. **Behavior control** : • Behavior control allows to control the use of any particular service. For example, the firewall may filter e-mails to eliminate spam.

6.14.1 Types of Firewall

- Commonly used firewalls from threats of security are,
 1. Packet filtering router
 2. Application level gateways
 3. Circuit level gateways.